

GESTIÓN DE CIBERSEGURIDAD : Acceso no autorizado a información

1°.- Preparación

Políticas y procedimientos: El centro debe tener un plan de respuesta a incidentes y una política de contraseñas (cambios periódicos, doble factor).

Formación: Alumnos, profesores y personal administrativo deben saber no compartir credenciales, detectar phishing y proteger documentos físicos.

Herramientas: Firewall, sistemas de detección de intrusiones (IDS), cifrado de tráfico (HTTPS, VPN), cajones con llave para documentos físicos.

Equipo de respuesta: Designar un coordinador de ciberseguridad (p.ej., el responsable TIC del centro).

2°.- Identificación

Señales de alerta:

- o Actividad inusual en cuentas de usuarios (accesos a horas extrañas, desde ubicaciones raras).
- o Un profesor o alumno reporta que no puede entrar a su cuenta o ve cambios no hechos por él.
- o Documentos físicos de contraseñas aparecen movidos o faltan en la secretaría.

Origen:

- o Interceptación de tráfico (WiFi escolar no seguro, ataque Man-in-the-Middle).
- o Acceso físico a papeles con credenciales (pizarra apuntada, nota adhesiva en el escritorio).

Registro: Se documenta hora, cuentas afectadas y alcance (plataforma educativa, notas, correos).

3°.- Contención

- Acciones inmediatas:
 - o Cambiar la contraseña de la cuenta comprometida y forzar cierre de sesión en todos los dispositivos.
 - o Desconectar del equipo afectado si el acceso sigue activo.
 - o Si fue por documento físico, retirar y destruir ese papel, revisar quién tuvo acceso físico en ese periodo.

- Aislar: Si el atacante se movió a otros sistemas, aislar esos equipos de la red escolar.

4°.- Mitigación

- Eliminar la causa:

Si la interceptación fue por WiFi abierta, obligar a usar WPA2/WPA3 y red de invitados aislada.

Si fue por documento físico, implantar política de no escribir contraseñas en papeles; usar gestores de contraseñas (ej. Bitwarden, solo para personal).

- Reducir impacto:

Revisar logs de la cuenta comprometida: ¿se descargaron listados de alumnos? ¿se modificaron notas?

Notificar solo a los afectados (por ejemplo, padres si se accedió a datos personales de menores).

Bloquear IPs maliciosas si se identificaron.

5°.- Recuperación

- Restaurar:
 - o Recuperar desde copia de seguridad cualquier dato modificado o borrado.
 - o Si la plataforma educativa quedó dañada, reinstalar desde imagen limpia.
- Reestablecer acceso:
 - o Entregar nueva contraseña segura al usuario afectado (por canal seguro, no por correo no cifrado).
 - o Activar 2FA en cuentas críticas (secretaría, dirección, jefatura de estudios).
- Validar: Verificar que la cuenta ya no tiene actividad extraña y que el punto de entrada está cerrado (WiFi seguro, documentos bajo llave).

6°.- Actuaciones post-incidente

Análisis de causa raíz: ¿Por qué se pudo interceptar tráfico? ¿Por qué había credenciales escritas en un papel accesible?

- Lecciones aprendidas:
 - o El centro necesita cifrar todo el tráfico interno relevante.
 - o Obligar a usar autenticación multifactor para profesores y personal.
 - o Prohibir por normativa dejar contraseñas en documentos físicos; formar de nuevo.
- Actualización de la preparación:
 - o Incluir este caso en simulacros de ciberseguridad con el claustro.

- o Revisar el armario donde se guardan documentos sensibles (cerradura, registro de quién accede).
- Registro oficial: Documentar el incidente (fecha, duración, cuentas, acciones tomadas) para auditorías o notificaciones legales (LOPD/GDPR si hay datos personales de alumnos).